

INTRODUCTION

Ethical Hacking

Eng. Zahra Rajeh, M.Sc.

You can't possibly prevent what you don't understand. But understanding without ethics is like having the keys to every door.

Promise yourself you'll only open the right ones

DISCUSSION

- What came to mind when you heard the term 'hacker'?
- Is it possible for an action to be legal but unethical, or illegal but ethical?
- By the end of this course, you'll have skills that could be used for defense or offense. What personal rule will you set for yourself to ensure you never misuse these techniques?





OUTLINE

Introduction

Security basics

Access control systems

Security policies

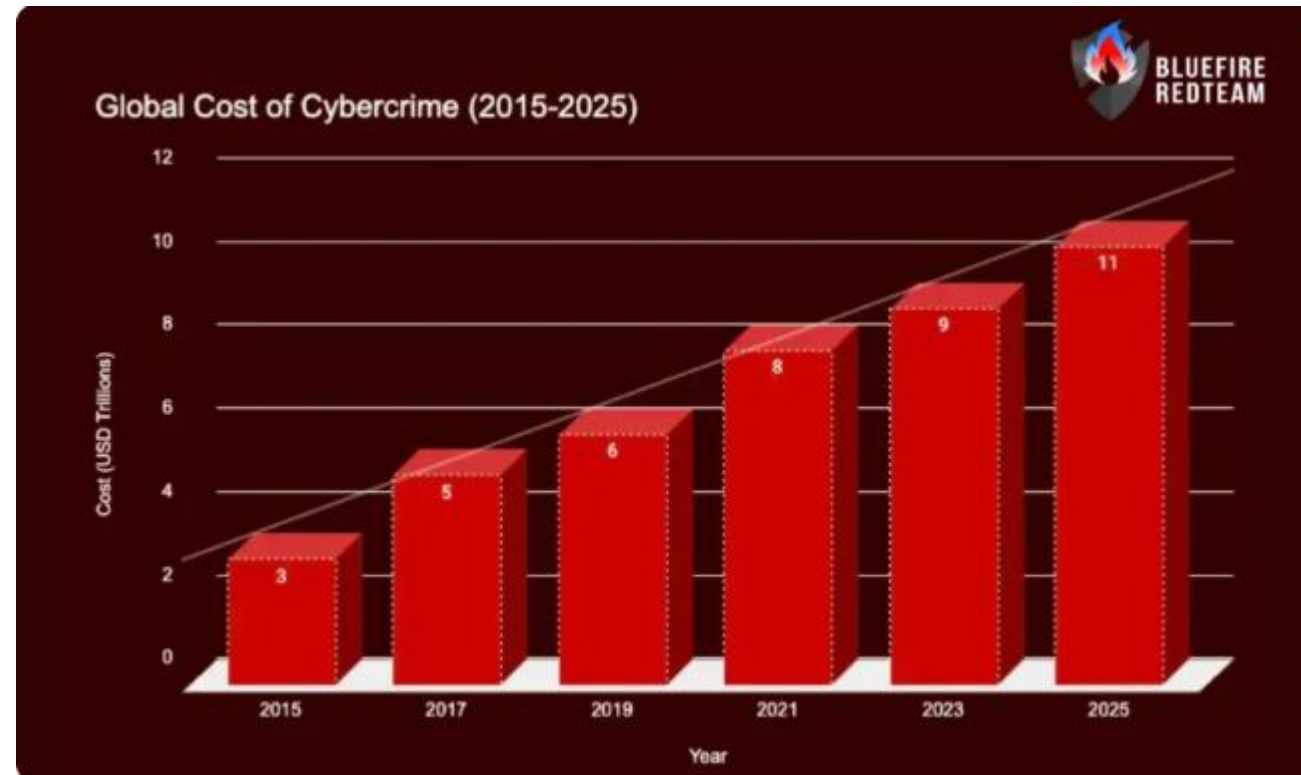
Introduction to ethical hacking

INTRODUCTION

Ethical hacking is the authorized practice of testing systems, networks, and applications to identify and fix security weaknesses before malicious attackers exploit them. Ethical hackers use real hacking techniques with permission to strengthen cybersecurity and protect digital assets.

INTRODUCTION

According to estimates, cybercrime is costing almost 10.29 trillion U.S. dollars worldwide in 2025, and it is projected to increase to approximately 16 trillion U.S. dollars by 2029. Cybercrime takes many forms – phishing, ransomware, credential theft, fraud, among others.



INTRODUCTION

The aspects ensure that ethical hacking remains structured, legal, and focused on improving cybersecurity.

- **Permission-Based:** This permission becomes necessary to differentiate their job from criminal hacking jobs
- **Methodology:** Ethical hackers perform these steps using a variety of tools and techniques, similar to criminal hackers.
- **Objective:** The main goal is to find the holes before hostile attackers can penetrate them.
- **Reporting:** Ethical hackers report back to the organization with the results of the tests.



1. Permission



2. Methodology



3. Objective



4. Reporting

Ethical Hacking

SECURITY BASICS

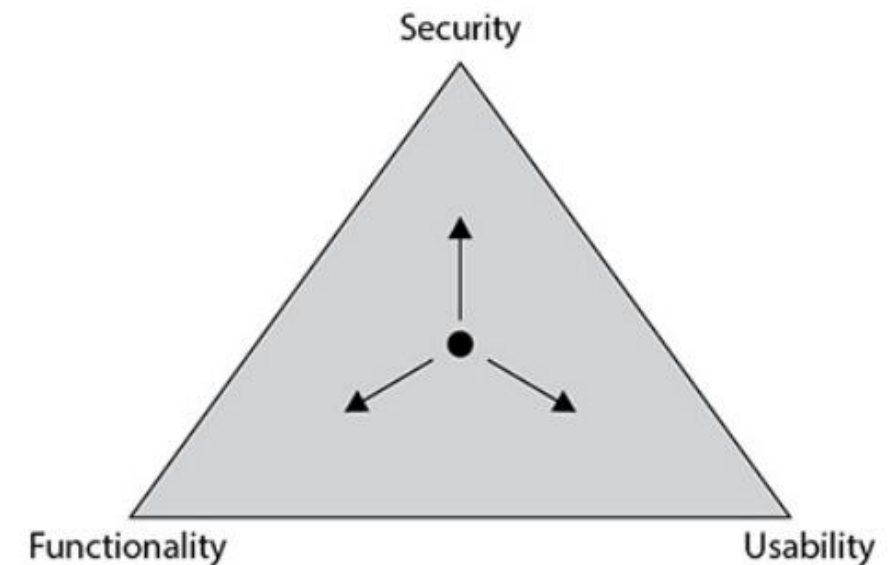
SECURITY BASICS

Security basics revolve around preventing unauthorized access, protecting data, and maintaining system availability.

SECURITY BASICS

The **Security Triangle** (often called the "**Iron Triangle of Cybersecurity**") consists of:

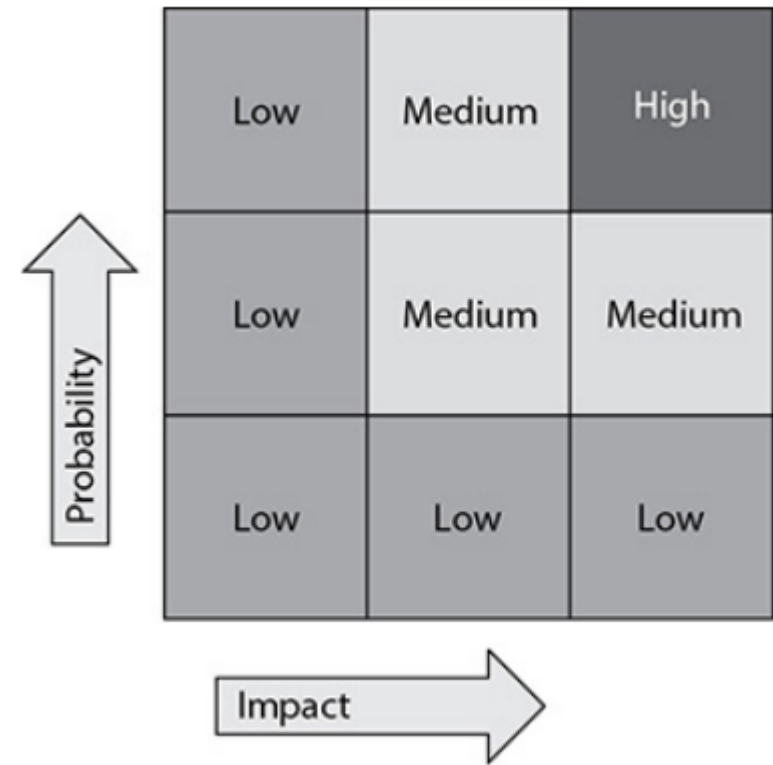
- **Security:** The safeguards, restrictions, and controls put in place to protect data and prevent unauthorized access.
- **Functionality:** The features, capabilities, and options a system offers to meet user needs.
- **Usability:** The ease with which users can navigate, learn, and utilize the system



SECURITY BASICS

Risk management

Identifying organizational assets, along with the threats and vulnerabilities that affect them, enables an organization to determine appropriate security countermeasures. Implementing these security controls helps reduce risks and significantly improves the overall security posture of the organization's systems.



SECURITY BASICS

A risk matrix is used to scale risk by considering the **probability, likelihood**, and **consequence/impact** of the risk

Probability		Consequences				
		Insignificant	Minor	Moderate	Major	Severe
81-100%	Likelihood	Very High Probability	Low	Medium	High	Extreme
61 - 80%		High Probability	Low	Medium	High	Extreme
41 – 60%		Equal Probability	Low	Medium	Medium	High
21 - 40%		Low Probability	Low	Low	Medium	Medium
1 – 20%		Very Low Probability	Low	Low	Medium	Medium

SECURITY BASICS

Controls to be put into place to prevent errors or incidents from occurring in the first place; some were to identify an incident had occurred or was in progress, and some were designed for after the event to limit the extent of damage and aid swift recovery, defined as:

- preventative
- detective
- Corrective

SECURITY BASICS

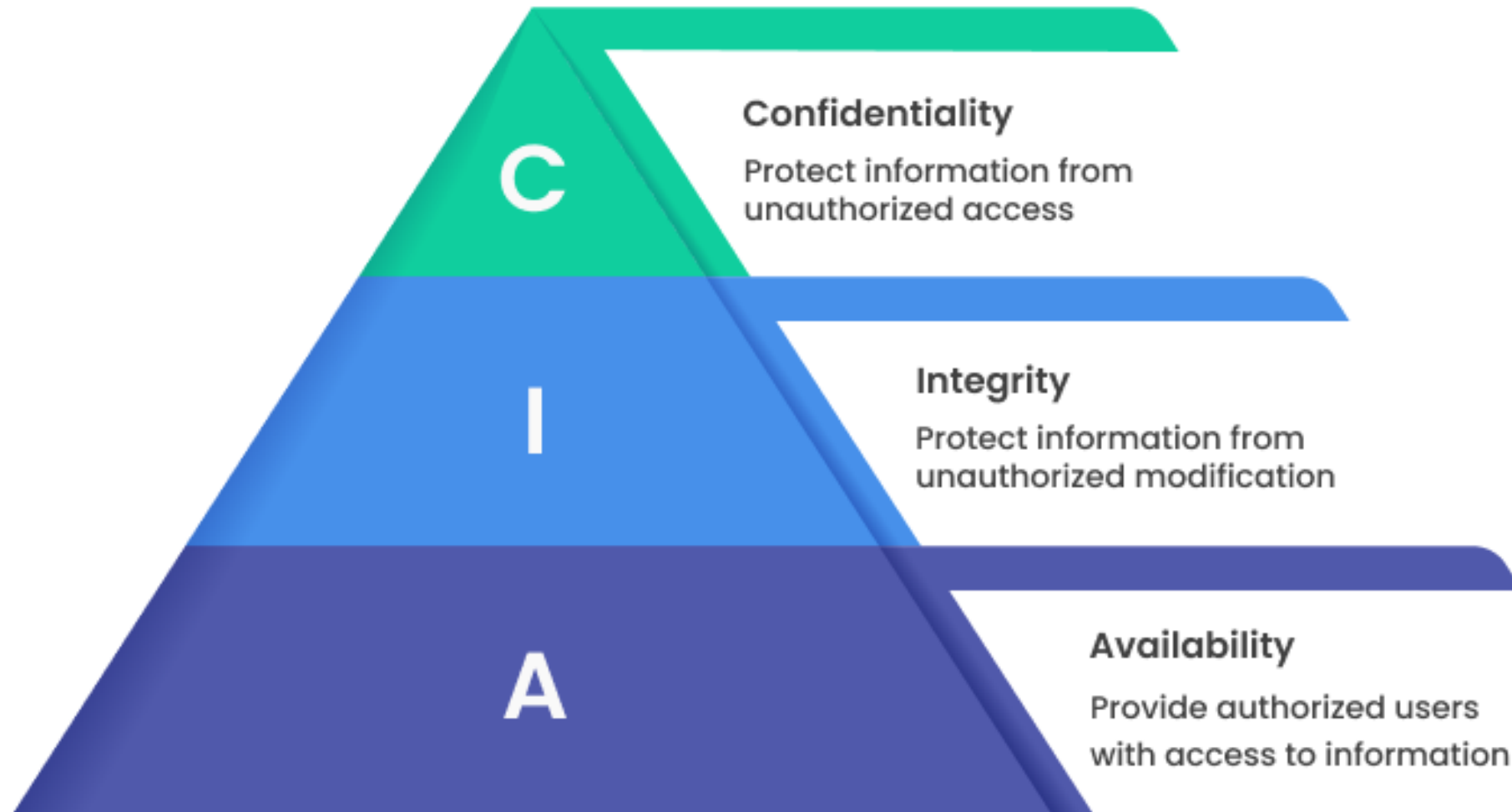
Another bedrock in any security basics discussion is **the triangle of IT security**: confidentiality, integrity, and availability (CIA).

The Core Principles

Information security stands on three primary pillars:

- **Confidentiality:** Ensuring data is only accessible to authorized individuals.
- **Integrity:** Protecting data from unauthorized alterations or corruption.
- **Availability:** Ensuring authorized users can access systems and data whenever needed.

Three main principles of information security



ACCESS CONTROLS AND SECURITY POLICIES

ACCESS CONTROL SYSTEMS

Access control basically means restricting access to a resource in some selective manner.

- **Mandatory access control** (abbreviated to MAC) is a method of access control where security policy is controlled by a security administrator: users can't set access controls themselves.
- **Discretionary access control** (DAC) puts a lot of this power in the hands of the users themselves. DAC allows users to set access controls on the resources they own or control.

SECURITY POLICIES

A security policy can be defined as a document describing the security controls implemented in a business to accomplish a goal.

There are worlds of different security policy types, with some of the more common ones identified here:

- **Access Control Policy**, This identifies the resources that need protection and the rules in place to control access to those resources.
- **Information Security Policy**, This identifies to employees what company systems may be used for, what they cannot be used for, and what the consequences are for breaking the rules

SECURITY POLICIES

- **Information Protection Policy:** This defines information sensitivity levels and who has access to those levels. It also addresses how data is stored, transmitted, and destroyed.
- **Password Policy:** This defines everything imaginable about passwords within the organization, including length, complexity, maximum and minimum age, and reuse.
- **E-mail Policy:** sometimes also called the E-mail Security Policy, addresses the proper use of the company e-mail system.
- **Information Audit Policy:** This defines the framework for auditing security within the organization. When, where, how, how often, and sometimes even who conducts information security audits are described here.

INTRODUCTION TO ETHICAL HACKING

ETHICAL HACKING DEFINITION

Ethical hacking, also known as "white-hat hacking" or penetration testing, is the use of hacking techniques by friendly parties in an attempt to uncover, understand, and fix security vulnerabilities in a network or computer system.

Ethical hackers have the same skills and use the same tools and tactics as malicious hackers, but their goal is always to improve network security without harming the network or its users.

HACKER CLASSIFICATIONS: THE HATS

White hats, Considered the good guys, these are the ethical hackers, hired by a customer for the specific goal of testing and improving security or for other defensive purposes.

Black hats, Considered the bad guys, these are the crackers, illegally using their skills for either personal gain or malicious intent. They seek to steal (copy) or destroy data and to deny access to resources and systems.

Gray hats, The hardest group to categorize, these hackers are neither good nor bad. Generally speaking, there are two subsets of gray hats—those who are simply curious about hacking tools and techniques and those who feel like it's their duty, with or without customer permission, to demonstrate security flaws in systems.

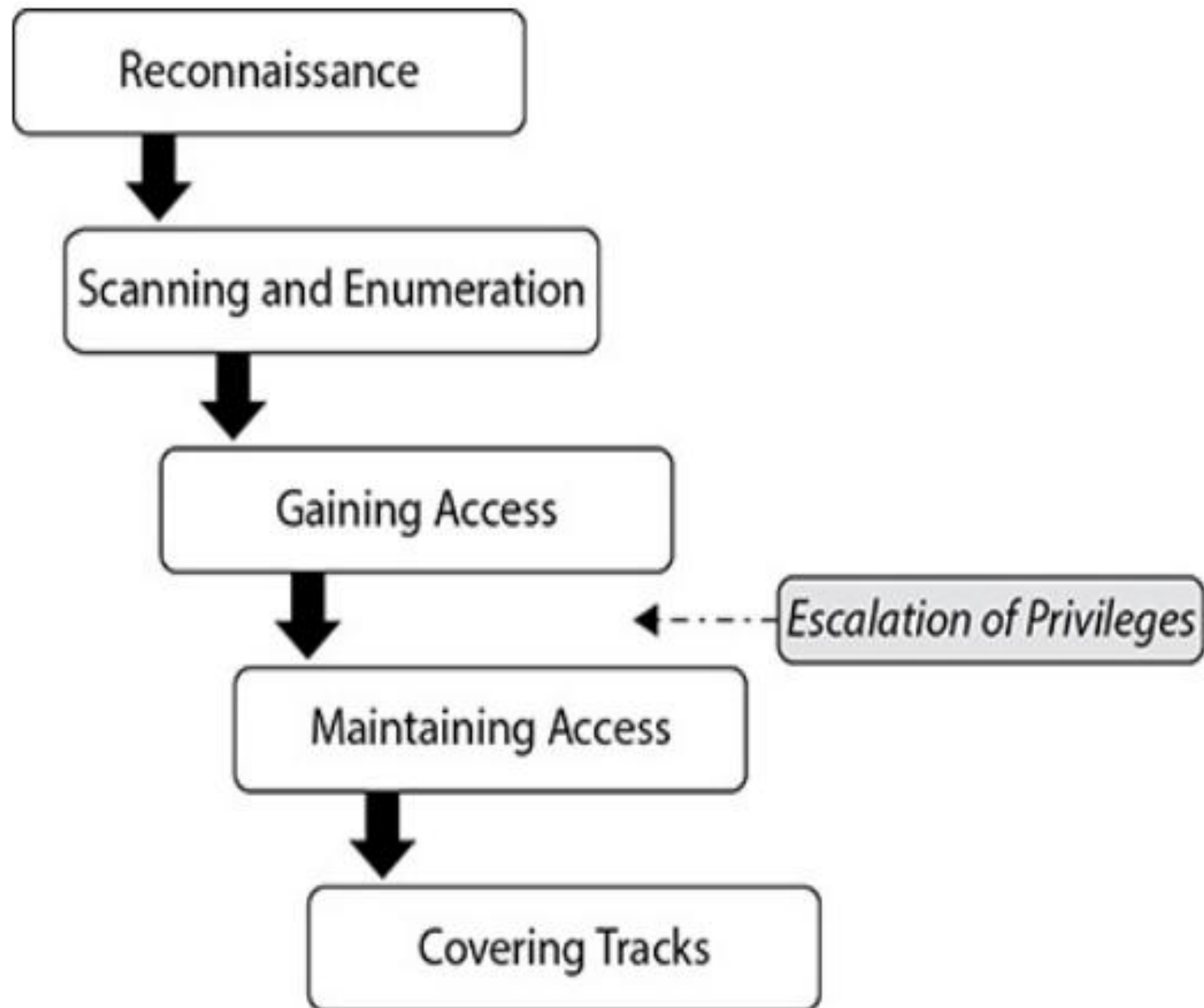
ATTACK TYPES

- **Operating system (OS) attacks:** these attacks target the common mistake many people make when installing operating systems—accepting and leaving all the defaults.
- **Application-level attacks:** These are attacks on the actual programming code and software logic of an application.
- **Shrink-wrap code attacks:** These attacks take advantage of the built-in code and scripts most off-the-shelf applications come with.
- **Misconfiguration attacks:** These attacks take advantage of systems that are, on purpose or by accident, not configured appropriately for security.

ETHICAL HACKING PHASES

Hacking phases, as identified by EC-Council, are a great way to think about an attack structure. Ethical hacking phases:

- Reconnaissance
- scanning and enumeration
- gaining access
- maintaining access
- covering tracks



ETHICAL HACKING PHASES

Reconnaissance is nothing more than the steps taken to gather evidence and information on the targets you want to attack.

In the second phase, **scanning and enumeration**, security professionals take the information they gathered in recon and actively apply tools and techniques to gather more in-depth information on the targets.

In the **gaining access** phase, true attacks are leveled against the targets enumerated in the second phase.

ETHICAL HACKING PHASES

In the fourth phase, **maintaining access**, hackers attempt to ensure they have a way back into the machine or system they've already compromised. The attacker leaves back doors open for future use.

In the final phase, **covering tracks**, attackers attempt to conceal their success and avoid detection by security professionals. Steps taken here consist of removing or altering log files, or hiding files with hidden attributes or directories.

PENETRATION TESTING

Penetration testing is a simulation of ethical hacking, also known as pen testing. In performing a pen test, an ethical hacker must attempt to mirror the criminal world as closely as possible.

In other words, if the steps taken by the ethical hacker during the pen test don't adequately mirror what a "real" hacker would do, then the test is doomed to failure.

PENETRATION TESTING

In **black-box testing**, the ethical hacker has absolutely no knowledge of the TOE. The testing is designed to simulate an outside, unknown attacker, and it takes the most amount of time to complete and, usually, is by far the most expensive option.

White-box testing is the exact opposite of black-box testing. In this type, pen testers have full knowledge of the network, system, and infrastructure they're targeting.

Gray-box testing is also known as partial knowledge testing. Gray-box testing assumes only that the attacker is an insider. This type of testing is valuable and can demonstrate privilege escalation from a trusted employee.

LAWS AND STANDARDS

There are tons of laws you need to be aware of for your job, such as

- FISMA,
- Electronics Communications Privacy Act,
- PATRIOT Act,
- Privacy Act of 1974,
- Cyber Intelligence Sharing and Protection Act (CISPA),
- Consumer Data Security and Notification Act,
- Computer Security Act of 1987
- ...the list really is almost endless.

SUMMARY

Topics covered in this lecture:

- Introduction
- Security basics
- Introduction to ethical hacking

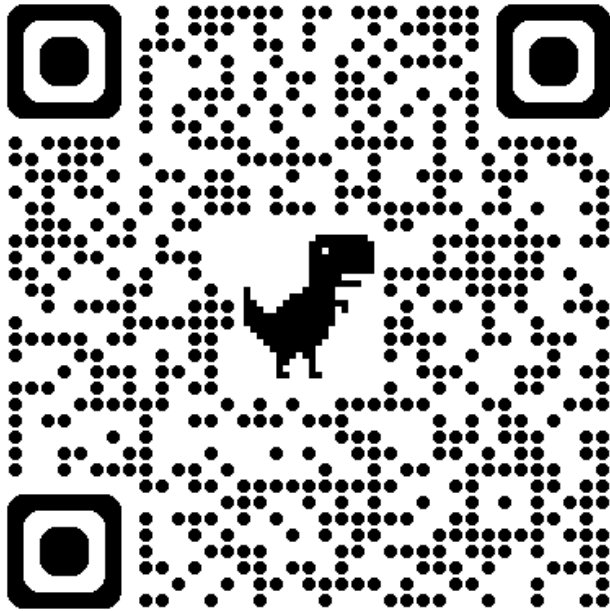
ASSESSMENT POLICY

Method	Marks
Assignments	5
Quizzes	5
Midterm exam (theory)	10
Lap part	30
Final exam (theory)	50
Total	100



REGISTRATION

REGISTER IN THE ETHICAL HACKING CLASSROOM



<https://forms.gle/jFC4DHj75KzDUJ7U6>

Ethical hacking - E -2026

[تحميل الحساب](#) z.rajuh22@gmail.com

غير مشترك 

* تشير إلى أن السؤال مطلوب

اسم لطالب *

إجابته

الرقم الأكاديمي *

إجابته

عنوان البريد الإلكتروني *

إجابته

محو النموذج

